

Security+ 5.4 · Privacy

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 5.4** —

Privacy (5:21) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Privacy encompasses legal implications (GDPR, CCPA, LGPD, HIPAA) and data responsibilities (owner/controller/processor/custodian). It requires maintaining an inventory of what data you have and where, and enforcing retention policies (keep only as long as legally necessary; GDPR mandates deletion when no longer needed).

High-Yield Core Concepts Tested on Exam

- Privacy laws protect personal data (GDPR/CCPA/LGPD)
- Data minimization: collect only what is necessary; retention: keep only for the legal period
- Roles: data owner, controller, processor, custodian
- Data inventory: know what data you have and where it resides
- GDPR right to erasure: users can request deletion of their data

Exam Tips & Classic Scenarios

- 'right to request deletion of your data' = GDPR right to erasure
- If a user asks to delete their data, think GDPR right to erasure

Typical Exam Scenario: A European user asks a website to delete their data. This is an example of the GDPR right to erasure.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 5.4 — Privacy)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Which law regulates the protection of personal data in the European Union?

- A)** HIPAA
- B)** GLBA
- C)** GDPR
- D)** SOX

2. Corporate scenario (Privacy): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.4), an analyst evaluates the following technical requirement: 'Privacy: LAWS for personal data protection (GDPR/CCPA/LGPD)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Privacy: LAWS for personal data protection (GDPR/CCPA/LGPD)...

3. Corporate scenario (Privacy): During a security review and compliance audit for the CompTIA Security+ exam (SY0-701, Section 5.4), an analyst evaluates the following technical requirement: 'Data minimization: collect only the NECESSARY; retention: keep only for the legal time'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal adherence terms
- C)** Implement the corresponding solution: Data minimization: collect only the NECESSARY; retention: keep only for the legal time...
- D)** Allow shared access among administrators with generic credentials

4. Corporate scenario (Privacy): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.4), an analyst evaluates the following technical requirement: 'right to request deletion of your data' = GDPR right to erasure. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'right to request deletion of your data' = GDPR right to erasure...

5. Corporate scenario (Privacy): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.4), an analyst evaluates the following technical requirement: 'European user asks the site to delete their data' = GDPR right to erasure. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'European user asks the site to delete their data' = GDPR right to erasure.
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Privacy): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.4), an analyst evaluates the following technical requirement: 'Privacy: LAWS for personal data protection (GDPR/CCPA/LGPD)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Privacy: LAWS for personal data protection (GDPR/CCPA/LGPD)...

7. Corporate scenario (Privacy): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.4), an analyst evaluates the following technical requirement: 'Data minimization: collect only the NECESSARY; retention: keep only for the legal time'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Data minimization: collect only the NECESSARY; retention: keep only for the legal time...
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Privacy): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.4), an analyst evaluates the following technical requirement: 'right to request deletion of your data'=GDPR right to erasure'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'right to request deletion of your data'=GDPR right to erasure...
- D)** Allow shared access among administrators with generic credentials

9. Corporate scenario (Privacy): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.4), an analyst evaluates the following technical requirement: 'European user asks the site to delete their data'=GDPR right to erasure.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'European user asks the site to delete their data'=GDPR right to erasure....

10. Corporate scenario (Privacy): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.4), an analyst evaluates the following technical requirement: 'Privacy: LAWS for personal data protection (GDPR/CCPA/LGPD).' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Privacy: LAWS for personal data protection (GDPR/CCPA/LGPD).
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) C — GDPR.

✓ **Why it is correct:** The GDPR (General Data Protection Regulation) is the European Union's regulation that establishes strict rules on the collection, processing, storage, and transfer of personal data of individuals in the EU. It came into effect in 2018 and imposes extraterritorial obligations, affecting organizations anywhere that process data of European residents. CompTIA Security+ includes GDPR as a central example of privacy and data protection regulation.

✗ Why the others are wrong:

- *HIPAA:* The Health Insurance Portability and Accountability Act is a United States law that regulates the privacy and security of protected health information (PHI). It applies to healthcare entities, health plans, and business associates in the US, not to general personal data protection in the European Union. Therefore, it is not the correct legislation for the European scope.
- *GLBA:* The Gramm-Leach-Bliley Act is a US law that requires financial institutions to explain how they share personal financial information and to protect sensitive data. Its focus is the US financial sector, not the broad protection of personal data of European citizens. It does not apply to the European Union context.
- *SOX:* The Sarbanes-Oxley Act is a US law that establishes auditing and financial control requirements for publicly traded companies, aiming to prevent accounting fraud. Although it has information security implications, it does not regulate personal data protection in the EU. It is focused on corporate governance and financial reporting, not European data privacy.

2) D — Implement the corresponding solution: Privacy: LAWS for personal data protection (GDPR/CCPA/LGPD)....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.4 (Privacy): Privacy: LAWS for personal data protection (GDPR/CCPA/LGPD).

✗ Why the others are wrong:

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

3) C — Implement the corresponding solution: Data minimization: collect only the NECESSARY; retention: keep only for the legal time....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.4 (Privacy): Data minimization: collect only the NECESSARY; retention: keep only for the legal time.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal adherence terms:* Informal terms are

administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.

- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

4) D — Implement the corresponding solution: 'right to request deletion of your data' = GDPR right to erasure....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.4 (Privacy): 'right to request deletion of your data' = GDPR right to erasure.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

5) B — Implement the corresponding solution: 'European user asks the site to delete their data' = GDPR right to erasure..

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.4 (Privacy): 'European user asks the site to delete their data' = GDPR right to erasure. The GDPR right to erasure (also known as the right to be forgotten) allows individuals to request the deletion of their personal data under certain circumstances.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) D — Implement the corresponding solution: Privacy: LAWS for personal data protection (GDPR/CCPA/LGPD)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.4 (Privacy): Privacy: LAWS for personal data protection (GDPR/CCPA/LGPD). GDPR (General Data Protection Regulation) is an EU regulation that governs data protection and privacy. CCPA (California Consumer Privacy Act) is a California state law that enhances privacy rights for residents. LGPD (Lei Geral de Proteção de Dados) is Brazil's data protection law. These laws impose requirements on how organizations collect, store, and process personal data, and they mandate security controls to protect that data.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) C — Implement the corresponding solution: Data minimization: collect only the NECESSARY; retention: keep only for the legal time....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.4 (Privacy): Data minimization: collect only the NECESSARY; retention: keep only for the legal time. Data minimization is a privacy principle that limits the collection of personal data to what is strictly necessary for a specified purpose. Retention policies define how long data must be kept to comply with legal, regulatory, or business requirements, after which it should be securely deleted. Together, these controls reduce the risk of data breaches and ensure compliance with privacy regulations such as GDPR. This is a preventive and compliance control.

✗ **Why the other options are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) C — Implement the corresponding solution: 'right to request deletion of your data'=GDPR right to erasure....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.4 (Privacy): 'right to request deletion of your data'=GDPR right to erasure.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) D — Implement the corresponding solution: 'European user asks the site to delete their data'=GDPR right to erasure.....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.4 (Privacy): 'European user asks the site to delete their data'=GDPR right to erasure. The

GDPR's right to erasure (right to be forgotten) allows individuals to request deletion of their personal data under certain conditions. The correct action is to implement the corresponding data deletion process.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: Privacy: LAWS for personal data protection (GDPR/CCPA/LGPD)..

The correct answer is to implement the corresponding solution: comply with personal data protection laws such as GDPR, CCPA, and LGPD. According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.4 (Privacy), organizations must understand and adhere to legal frameworks governing the collection, processing, and storage of personally identifiable information (PII). Distractor breakdown: • *Temporarily disable audit logs to accelerate system throughput*: Incorrect. This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001). • *Replace preventive technical controls with informal terms of adherence*: Incorrect. Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware. • *Allow shared access among administrators using generic credentials*: Incorrect. This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.